

Risk ID	Risk Description	Business Impact
IAM-001	Dormant Account Exploitation	Attackers or malicious insiders exploit stale accounts that were not disabled upon employee departure, gaining unauthorised access to sensitive systems and data.
IAM-002	Excessive Privilege Accumulation	Users accumulate privileges over time through role changes, project assignments, or poor offboarding, violating least privilege and increasing the blast radius of compromise.
IAM-003	Uncontrolled Privileged Access (PAM Gaps)	Privileged accounts (Domain Admins, root, service owners) are used without session recording, approval workflows, or time-limited just-in-time access, enabling undetected misuse.
IAM-004	Joiners-Movers-Leavers (JML) Process Failures	Inadequate or delayed JML processing results in new starters lacking timely access, movers retaining legacy permissions, and leavers retaining active accounts post-termination.
IAM-005	Shared Account Usage	Teams share generic or functional accounts (e.g., 'admin', 'svc_support'), preventing individual accountability, complicating audit trails, and increasing credential exposure risk.
IAM-006	Segregation of Duties (SoD) Conflicts	Critical business functions (e.g., raise and approve payment, create and authorise user accounts) are accessible by a single user, enabling fraud or error without detection.
IAM-007	Inadequate Multi-Factor Authentication (MFA) Coverage	MFA is not enforced for all users accessing sensitive systems, remote access, or cloud services, leaving accounts vulnerable to credential stuffing, phishing, and password spray attacks.
IAM-008	Unmanaged Service Accounts	Service accounts are created ad hoc, use long-lived static credentials, are over-privileged, and lack ownership documentation, creating persistent backdoor risk.
IAM-009	Access Review Failures	Periodic access reviews (recertifications) are not completed on time, are rubber-stamped without scrutiny, or lack evidence for audit purposes, leaving inappropriate access in place.
IAM-010	Identity Lifecycle Management Gaps	Identities are not consistently managed across their full lifecycle (creation, modification, suspension, deletion), leading to orphaned accounts, stale permissions, and audit findings.

Risk ID	Risk Description	Business Impact
IAM-011	Third-Party Access Without Governance	Vendors, partners, and suppliers are granted access to internal systems without formal approval, time-limiting, periodic review, or monitoring, increasing supply chain risk.
IAM-012	Contractor Access Over-Provisioning	Contractors are granted excessive or persistent access beyond their project scope, often not revoked upon contract end, creating residual access risk.
IAM-013	Privileged Session Monitoring Gaps	Sessions conducted under privileged accounts are not recorded or are inadequately monitored, preventing forensic investigation and enabling malicious insiders to operate undetected.
IAM-014	Role-Based Access Control (RBAC) Immaturity	RBAC frameworks are poorly defined, with too many roles, inconsistent role definitions, or direct permission assignments, making access management unscalable and ungovernable.
IAM-015	Weak Password Policy Enforcement	Password policies are insufficiently complex, not uniformly enforced across all systems, or lack breach password screening, enabling credential-based attacks.
IAM-016	Conditional Access Policy Gaps	Conditional Access Policies (CAPs) are missing, misconfigured, or incomplete, failing to enforce context-aware controls (device compliance, location, risk score) before granting access.
IAM-017	Identity Governance Failures	Absence of a formal Identity Governance and Administration (IGA) programme means there is no centralised visibility, policy enforcement, or audit capability across the identity estate.
IAM-018	Cloud Identity and Access Risks	Cloud environments (AWS, Azure, GCP) have misconfigured IAM roles, over-permissive service principals, or lack of centralised cloud identity governance, expanding the attack surface.
IAM-019	Active Directory Security Risks	Active Directory misconfigurations (Kerberoastable accounts, unconstrained delegation, stale GPOs, AdminSDHolder abuse) provide attackers with lateral movement and privilege escalation vectors.
IAM-020	Microsoft Entra ID Governance Risks	Entra ID (Azure AD) is not fully configured for governance: guest accounts are uncontrolled, Entra ID Governance entitlement management is unused, and PIM is not enforced for privileged roles.

IAM GOVERNANCE RISK REGISTER

Likelihood	Impact	Inherent Risk	Existing Controls
Medium	High	High	No formal periodic review cadence; partial HR-IT offboarding checklist
High	High	Critical	Role reviews conducted annually; manual provisioning process
High	High	Critical	Some PAM tooling deployed; not universally enforced
High	High	Critical	Manual HR tickets; no SLA enforced on IT provisioning
Medium	Medium	Medium	Policy prohibiting shared accounts exists; enforcement inconsistent
High	High	Critical	Some SoD rules defined in ERP; not enforced cross-system
High	High	Critical	MFA enforced for VPN; gaps exist for SaaS apps and internal portals
Medium	Medium	Medium	No formal service account register; password rotation sporadic
Medium	High	High	Annual access reviews conducted; completion rate ~60%
High	High	Critical	Partial lifecycle controls via AD; no unified IGA platform

IAM GOVERNANCE RISK REGISTER

Likelihood	Impact	Inherent Risk	Existing Controls
Medium	High	High	Vendor access granted via IT request; no centralised registry
Medium	High	High	Contractor access managed via standard HR process; no separate lifecycle
Medium	High	High	Some session logging in place; not enforced uniformly
Medium	Medium	Medium	Basic role structure exists in AD; significant role sprawl
Medium	Medium	Medium	Password policy defined in AD GPO; not enforced on all legacy systems
High	High	Critical	Some CAPs in Microsoft Entra; coverage incomplete; no named exclusion governance
High	High	Critical	Ad hoc identity governance; no IGA platform deployed
High	High	Critical	Cloud IAM policies partially reviewed; no CIEM tooling deployed
High	High	Critical	AD managed by IT Ops; no formal AD security hardening programme
High	High	Critical	Entra ID deployed; PIM partially configured; no entitlement management

Recommended Mitigation Actions	Risk Owner	ISO 27001 Control
Implement automated 30/60/90-day dormancy detection and auto-disable workflow; integrate HR system with IAM platform for real-time account suspension on leaver events; quarterly access recertification campaigns.	IAM Manager / HR Director	A.9.2.5
Enforce least-privilege provisioning by default; implement role mining to detect privilege creep; mandate semi-annual access recertification with automated revocation of uncertified entitlements.	IAM Manager / Risk Officer	A.9.2.2
Deploy enterprise PAM solution (e.g., CyberArk, BeyondTrust) with vaulted credentials, just-in-time access, dual-approval workflows, and mandatory session recording for all Tier-0 and Tier-1 assets.	CISO / IT Security Lead	A.9.4.4
Automate JML via HR-to-IAM integration (e.g., SAP SuccessFactors → Microsoft Entra); define and enforce SLAs: joiners <4 hrs, movers <24 hrs, leavers <1 hr; conduct monthly JML audit reports.	IAM Manager / HR Director	A.9.2.1
Eliminate shared accounts; replace with named individual accounts and role groups; where technical constraints exist, implement shared account check-out via PAM with full attribution logging.	IT Security / Application Owners	A.9.2.3
Implement SoD conflict matrix across all critical applications; deploy IGA tooling (e.g., SailPoint, Saviynt) with automated SoD detection; enforce compensating controls (audit logs, manager review) where SoD cannot be split.	IAM Manager / CFO / Risk Officer	A.6.1.2
Mandate MFA for all identity types (employees, contractors, service accounts where applicable); enforce phishing-resistant MFA (FIDO2/passkeys) for privileged users; monitor MFA bypass attempts via SIEM.	CISO / IAM Manager	A.9.4.2
Establish a service account registry with named owners; enforce automated credential rotation via PAM or secrets management (e.g., HashiCorp Vault); apply least-privilege scoping; disable unused service accounts quarterly.	IAM Manager / Application Owners	A.9.2.3
Migrate to IGA-driven quarterly access reviews; implement manager and application owner workflows; track completion rates as a KRI; escalate overdue reviews to CISO; retain audit-ready evidence for 3 years.	IAM Manager / Line Managers	A.9.2.5
Implement an IGA platform as a single authoritative source for identity lifecycle; automate provisioning/deprovisioning via connectors to all target systems; enforce lifecycle governance policies with quarterly compliance reporting.	IAM Manager / IT Director	A.9.2.1

Recommended Mitigation Actions	Risk Owner	ISO 27001 Control
Implement a third-party identity governance programme; use a dedicated third-party access portal with time-bound access, named sponsor accountability, and mandatory quarterly reviews; log all vendor sessions.	Risk Officer / Procurement / IAM Manager	A.15.1.1
Create a contractor identity lifecycle with contract-end hard-stop automation; scope access strictly to project requirements; implement contractor access reviews monthly; integrate with contract management system.	IAM Manager / HR / Procurement	A.9.2.2
Enforce privileged session recording for all Tier-0/1 systems via PAM; implement real-time anomaly alerting for unusual privileged session behaviour; retain recordings for minimum 12 months; conduct quarterly session log reviews.	CISO / SOC Lead	A.12.4.1
Conduct role engineering exercise to rationalise roles; implement a role lifecycle management process; enforce no direct permission assignments outside RBAC; define role ownership and mandate annual role reviews.	IAM Manager / Application Owners	A.9.2.2
Enforce minimum 12-character passwords with complexity and breach-password screening (e.g., Have I Been Pwned API); eliminate periodic forced resets in favour of breach-detection-triggered resets; enforce policy via Entra ID Password Protection.	IT Security / IAM Manager	A.9.4.3
Develop a Conditional Access policy framework covering all users and applications; eliminate broad exclusions; enforce compliant device requirement, MFA, and sign-in risk policies; review CAP effectiveness monthly via Entra ID reports.	CISO / IAM Manager	A.9.4.1
Establish a formal IGA programme with executive sponsorship; deploy an IGA platform (SailPoint, Saviynt, or Entra ID Governance); define governance policies, ownership, and quarterly board-level reporting.	CISO / CIO / Risk Officer	A.9.1.1
Deploy Cloud Infrastructure Entitlement Management (CIEM) tooling; enforce least-privilege cloud IAM roles; integrate cloud identities with enterprise IGA; implement continuous cloud entitlement monitoring with alerts for privilege escalation.	Cloud Security Lead / IAM Manager	A.9.2.2
Conduct an AD security health assessment (e.g., Purple Knight, PingCastle); remediate Kerberoastable SPNs, unconstrained delegation, and stale objects; implement tiered administration model; monitor AD changes via SIEM.	IT Security Lead / IAM Manager	A.9.4.4
Enforce Entra Privileged Identity Management (PIM) for all Entra roles; activate entitlement management for access packages; enforce guest account lifecycle with monthly reviews; enable Entra ID Access Reviews for all groups and applications.	IAM Manager / CISO	A.9.2.5

NIST CSF Control	Residual Risk
PR.AC-1	Medium
PR.AC-4	High
PR.AC-3	Medium
PR.AC-1	Medium
PR.AC-1	Low
PR.AC-4	Medium
PR.AC-7	Medium
PR.AC-1	Medium
DE.CM-3	Medium
PR.AC-1	Medium

NIST CSF Control	Residual Risk
ID.SC-3	Medium
PR.AC-1	Low
DE.CM-3	Low
PR.AC-4	Medium
PR.AC-7	Low
PR.AC-5	High
PR.AC-4	Medium
PR.AC-4	High
PR.AC-3	High
PR.AC-4	High

IAM Governance Risk Register — Executive Summary

Prepared by: IAM Governance Function | Audience: Executive Committee / Audit & Risk Committee | Classification:

1. PURPOSE & SCOPE

This Risk Register documents 20 identity and access management (IAM) risks identified across the enterprise identity premises Active Directory, Microsoft Entra ID (Azure AD), cloud platforms, privileged access infrastructure, and third-channels.

It is aligned to ISO 27001:2022 Annex A controls and the NIST Cybersecurity Framework 2.0, and is intended to support regulatory compliance, and the ongoing IAM Transformation Programme.

2. RISK PROFILE SUMMARY

- Critical Risks: 9 | High Risks: 7 | Medium Risks: 4 | Low Risks: 0
- Primary Risk Themes: Identity Lifecycle Governance gaps, Privileged Access Management deficiencies, Cloud Identity and inadequate Joiners-Movers-Leavers controls.
- The majority of Critical risks relate to systemic governance failures (no IGA platform, no formal PAM programme) rather than technical vulnerabilities — indicating strategic investment is required.

3. TOP 5 CRITICAL IAM RISKS

1. IAM-006 — Segregation of Duties Conflicts: Single users hold conflicting privileges across critical business processes undetected fraud. Urgent SoD matrix and IGA enforcement required.
2. IAM-007 — Inadequate MFA Coverage: Phishing-resistant MFA not enforced universally, leaving accounts exposed to attacks. Immediate Entra Conditional Access enforcement recommended.
3. IAM-017 — Identity Governance Failures: No enterprise IGA platform; identity governance is ad hoc and ungoverned. Initiation is the #1 strategic IAM priority.
4. IAM-019 — Active Directory Security Risks: AD contains known high-risk misconfigurations (Kerberoastable accounts enabling lateral movement). AD health assessment required within 30 days.
5. IAM-020 — Microsoft Entra ID Governance Risks: Entra PIM partially configured, guest accounts uncontrolled, emergency leaver process unused. Full Entra Governance activation required within 60 days.

4. RECOMMENDED 90-DAY IAM IMPROVEMENT PLAN

DAYS 1–30 (Immediate Actions): 1) Commission AD security health assessment & remediate critical findings. 2) Enforce privileged users and remote access via Conditional Access. 3) Implement emergency leaver process with <1hr SLA. 4) Establish account register and initiate PAM vaulting for Tier-0 credentials.

DAYS 31–60 (Foundation Building): 5) Activate Entra PIM for all Global Admin and privileged Entra roles. 6) Launch security awareness campaigns for all Tier-1 applications. 7) Begin role engineering and RBAC rationalisation exercise. 8) Establish third-party governance policy and contractor lifecycle controls.

DAYS 61–90 (Programme Establishment): 9) Initiate IGA platform procurement/deployment (SailPoint / Saviynt / Entraid). 10) Develop SoD conflict matrix and implement detective controls in ERP. 11) Deploy CIEM tooling for cloud IAM monitoring. 12) Establish Governance KPI dashboard to Risk Committee for baseline reporting.

5. KEY IAM GOVERNANCE METRICS (KPIs & KRIs)

KPIs: % of access reviews completed on time (Target: >95%) | % of leavers deprovisioned within SLA (Target: 100%) | users enrolled in PAM (Target: 100%) | MFA adoption rate across all users (Target: >99%) | % of service accounts with MFA (Target: 100%)

KRIs: Number of dormant accounts >30 days (Threshold: 0) | Number of SoD conflicts detected (Threshold: 0) | Number of unmitigated privileged sessions without recording (Threshold: 0) | Number of leavers with active accounts post-termination (Threshold: 0) | Number of cloud IAM roles with excessive permissions (Threshold: <5)

ARY

CONFIDENTIAL

ty estate, including on-
-party access

port audit readiness,

ntity misconfigurations,

ather than discrete

ses, enabling

ed to credential-based

nable. IGA programme

unts, unconstrained

titlement management

orce MFA for all
4) Create service

access review
-party access

ra ID Governance). 10)
ring. 12) Present IAM

) | % of privileged
with vaulted credentials

gated) | Number of
shold: 0) | Number of

IAM RISK HEAT MAP — 5×5 LIKELIHOOD

LIKELIHOOD ↓	IMPACT →			
	1 Negligible	2 Minor	3 Moderate	4 Major
5 — Almost Certain	Score: 5	Score: 10	Score: 15	Score: 20
4 — Likely	Score: 4	Score: 8	Score: 12 IAM-002 IAM-003 IAM-004 IAM-006 IAM-007 IAM-010 IAM-016 IAM-017 IAM-018 IAM-019 IAM-020	Score: 16
3 — Possible	Score: 3	Score: 6	Score: 9 IAM-001 IAM-005 IAM-008 IAM-009 IAM-011 IAM-012 IAM-013 IAM-014 IAM-015	Score: 12
2 — Unlikely	Score: 2	Score: 4	Score: 6	Score: 8
1 — Rare	Score: 1	Score: 2	Score: 3	Score: 4

HEAT MAP LEGEND

Score 20–25	Critical — Immediate Executive Action Required
Score 15–19	High — Senior Management Action Required
Score 10–14	High-Medium — Management Action Plan Required
Score 5–9	Medium — Monitor and Mitigate
Score 1–4	Low — Acceptable; Periodic Review

OD × IMPACT MATRIX

5 Catastrophic
Score: 25
Score: 20
Score: 15
Score: 10
Score: 5

IAM Governance — Key Performance Indicators			
Reporting Period: Q2 2026 Owner: IAM Governance Function			
Key Performance Indicators (KPIs)			
Metric ID	KPI Name	Description	Target
KPI-001	Access Review Completion Rate	% of periodic access reviews completed on time across all applications	≥95%
KPI-002	Leaver Deprovisioning SLA Adherence	% of leavers fully deprovisioned within 1 hour of HR notification	100%
KPI-003	Privileged User PAM Enrolment	% of privileged users with accounts managed within PAM solution	100%
KPI-004	MFA Adoption Rate — All Users	% of all users with MFA enforced across primary identity provider	≥99%
KPI-005	MFA Adoption — Privileged Users	% of privileged/admin users with phishing-resistant MFA (FIDO2/passkey)	100%
KPI-006	Service Account Credential Rotation	% of service accounts with automated credential rotation enforced	100%
KPI-007	Role Entitlement Accuracy	% of user roles matching approved job function profile (no excess)	≥98%
KPI-008	Third-Party Access Review Completion	% of third-party accounts reviewed and recertified within review period	≥95%
KPI-009	Privileged Session Recording Coverage	% of privileged sessions on Tier-0/1 systems captured and retained	100%
KPI-010	Onboarding Access Provisioning SLA	% of new joiners provisioned within 4 hours of start date confirmation	≥98%

Key Risk Indicators (KRIs)			
Metric ID	KRI Name	Description	Threshold (RAG)
KRI-001	Dormant Accounts >30 Days	Number of active accounts with no login in last 30 days	0 (Red >10)
KRI-002	Leavers with Active Accounts	Number of ex-employees retaining active identity accounts post-departure	0
KRI-003	Unresolved SoD Conflicts	Number of active, unmitigated SoD conflicts in critical systems	0

KRI-004	Privileged Accounts Outside PAM	Number of privileged accounts not vaulted in PAM solution	0
KRI-005	Failed MFA Bypass Attempts	Number of successful sign-ins after MFA challenge failure in 24hr	0
KRI-006	Cloud IAM Over-Privileged Roles	Number of cloud IAM roles with permissions significantly exceeding usage	<5
KRI-007	Unreviewed Third-Party Accounts	Number of vendor/supplier accounts not reviewed in >90 days	0
KRI-008	AD Critical Misconfigurations	Number of critical Active Directory misconfigurations (per AD health tool)	0
KRI-009	Entra PIM Uncovered Privileged Roles	Number of Entra privileged roles not governed by PIM	0
KRI-010	Contractor Accounts Post-Contract-End	Number of contractor accounts active beyond contract end date	0

PERFORMANCE & RISK INDICATORS

ction | Audience: CISO, Risk Committee, Audit Committee

Current Value	Status	Trend	Frequency	Owner	Evidence Source
62%	At Risk	↓ Declining	Quarterly	IAM Manager	IGA Platform / Review Tracker
78%	X Breach	↓ Declining	Monthly	IAM Manager / HR Director	HR-IAM Integration Logs
45%	X Breach	→ Flat	Monthly	IT Security Lead	PAM Admin Console
87%	At Risk	↑ Improving	Monthly	IAM Manager / CISO	Entra ID Sign-in Logs
52%	X Breach	↑ Improving	Monthly	CISO	Entra ID PIM Reports
31%	X Breach	→ Flat	Quarterly	IAM Manager	PAM / Secrets Vault Reports
71%	X Breach	→ Flat	Quarterly	IAM Manager	IGA Role Mining Report
40%	X Breach	→ Flat	Quarterly	Risk Officer	Vendor Access Registry
58%	X Breach	↑ Improving	Monthly	CISO / SOC Lead	PAM Session Recording Reports
83%	At Risk	↑ Improving	Monthly	IAM Manager / HR Director	ITSM / IAM Platform Ticket Logs

Current Value	Status	Risk Linked	Frequency	Owner	Action if Breached
47	RED	IAM-001	Weekly	IAM Manager	Immediate auto-disable; escalate to CISO
3	RED	IAM-004	Daily	IAM Manager / HR	Immediate disable; security investigation
12	RED	IAM-006	Monthly	Risk Officer / IAM Manager	Escalate to Risk Committee; emergency access review

38	RED	IAM-003	Weekly	IT Security Lead	Immediate onboarding to PAM; disable if not possible
N/A — Not Monitored	AMBER	IAM-007	Daily	SOC / IAM Manager	Enable SIEM alerting; review Entra sign-in risk logs
28	RED	IAM-018	Weekly	Cloud Security Lead	CIEM-driven right-sizing; remove unused permissions
19	RED	IAM-011	Monthly	Risk Officer	Suspend access pending review; sponsor accountability
7	RED	IAM-019	Weekly	IT Security Lead	Remediation plan within 72hrs; CISO notification
11	RED	IAM-020	Weekly	IAM Manager / CISO	Activate PIM for all privileged roles within 30 days
6	RED	IAM-012	Daily	IAM Manager / Procurement	Immediate suspension; review contract management process

DASHBOARD PAGES & VISUAL SPECIFICATIONS

Page / View	Visual Type	Title
1. Executive Overview	KPI Card (x4)	Open Critical Risks
1. Executive Overview	KPI Card (x4)	MFA Adoption Rate
1. Executive Overview	KPI Card (x4)	Leavers Not Deprovisioned
1. Executive Overview	Donut Chart	Risk Distribution by Level
1. Executive Overview	Horizontal Bar	Top 10 Risks by Inherent Score
1. Executive Overview	RAG Status Matrix	KPI / KRI RAG Scorecard
2. Risk Register View	Data Table	Full IAM Risk Register
2. Risk Register View	Scatter Plot	Risk Heatmap — Likelihood vs Impact
2. Risk Register View	Bar Chart	Risks by Category
3. KPI Performance	Line Chart	KPI Trend Over Time
3. KPI Performance	Gauge Chart	Access Review Completion Rate
3. KPI Performance	Gauge Chart	Leaver SLA Adherence
3. KPI Performance	Stacked Column	PAM Enrolment Progress
4. KRI Monitoring	KRI Alert Cards	Live KRI Status — 10 KRIs
4. KRI Monitoring	Column Chart	Dormant Accounts Over Time
4. KRI Monitoring	Map / Org Chart	SoD Conflicts by Business Unit

4. KRI Monitoring	Data Table	KRI Breach Log
5. Identity Lifecycle	Funnel Chart	JML Process Pipeline
5. Identity Lifecycle	Bar Chart	Provisioning SLA Performance
5. Identity Lifecycle	KPI Card	Orphaned Accounts — Total
6. Privileged Access	KPI Card	PAM Vaulting Coverage
6. Privileged Access	Line Chart	Privileged Session Volume
6. Privileged Access	Bar Chart	Privileged Accounts by Type
7. Cloud & Entra ID	Treemap	Cloud IAM Over-Permissioned Roles
7. Cloud & Entra ID	KPI Card	Entra PIM Coverage
7. Cloud & Entra ID	Column Chart	Guest Account Review Status
8. Audit & Compliance	Timeline	90-Day Remediation Plan Progress
8. Audit & Compliance	Data Table	Open Risks with Overdue Reviews
8. Audit & Compliance	KPI Card	ISO 27001 Control Coverage

OVERNANCE DASHBOARD — SPECIFICATION

Data Source / Field	KPI/KRI Linked	Filters / Slicers
Risk Register — Inherent Risk = Critical; COUNT	N/A	Date, Risk Category
Entra ID Sign-in Logs — MFA Enabled %	KPI-004	Date
HR-IAM Sync Log — Active accounts post-departure	KRI-002	Date
Risk Register — Inherent Risk Rating; COUNT by category	N/A	Risk Category, Date
Risk Register — Risk ID, Inherent Score; sorted DESC	N/A	Risk Category
KPI & KRI tables — Status field	All KPIs/KRIs	Reporting Period
Risk Register — all fields	N/A	Risk Category, Owner, Risk Level, Status
Risk Register — Likelihood (numeric), Impact (numeric), Risk ID	N/A	Risk Category
Risk Register — Risk Category; COUNT by Inherent Risk Level	N/A	Risk Level
KPI Historical Table — KPI ID, Value, Date	All KPIs	KPI Name, Date Range
IGA Platform — Reviews Completed / Total Reviews	KPI-001	Quarter, Application
HR-IAM Integration Log — SLA Met %	KPI-002	Month
PAM Admin — Enrolled vs Not Enrolled by Tier	KPI-003	Privilege Tier, Month
KRI Tracker — Current Value vs Threshold	All KRIs	KRI Name, Date
AD / Entra ID Audit — Accounts Inactive >30 days by week	KRI-001	Week, Department
IGA SoD Report — Conflicts by Dept; COUNT	KRI-003	Department, Application

KRI Tracker — Breached KRIs; Date, Value, Action Taken	All KRIs	Date, KRI ID
HR-IAM Integration — Joiner/Mover/Leaver events by stage	KPI-002, KPI-010	Month, Event Type
ITSM Tickets — Provisioning time (hrs) by event type	KPI-010	Month, Department
AD/Entra ID — Accounts with no owner attribute	KRI-001	Date
PAM Admin Console — Vaulted / Total Privileged Accounts	KPI-003	Tier, Month
PAM Session Logs — Sessions per day/week by Tier	KPI-009	Tier, Date
PAM Admin — Count by Type: Domain Admin, SA, Cloud Admin	KRI-004	Account Type
CIEM Tool — Roles by excess permission score	KRI-006	Cloud Platform, Date
Entra ID PIM — Roles in PIM / Total Privileged Roles	KRI-009	Date
Entra ID — Guest Accounts by Review Status (Reviewed/Pending/Expired)	IAM-020	Month
Remediation Tracker — Milestone, Target Date, Status	N/A	Risk ID, Owner
Risk Register — Review Date < Today; Status = Open	N/A	Risk Category, Owner
Risk Register — ISO 27001 Controls referenced / Total Annex A IAM controls	N/A	Date

Business Purpose
Single-number headline for board pack
Immediate visibility of authentication posture
Zero-tolerance KRI; red if >0
Proportion of Critical/High/Medium/Low risks
Prioritisation view for executive decisions
One-page governance health snapshot
Searchable, filterable risk register for analysts
Visual heat map with risk IDs plotted
Category breakdown: Cybersec, IAM, Operational, etc.
Show improvement/deterioration over reporting periods
Target line at 95%; green/amber/red zones
Critical metric; target 100%
Show PAM programme progress by privileged account tier
Real-time breach alerts with colour-coded status
Trend chart; target is 0; drill to department
Heatmap of SoD risk concentration by business area

Audit trail of all KRI breaches and remediation actions
Identify bottlenecks in identity provisioning workflow
Show SLA adherence distribution
Zero-tolerance metric for ungoverned identities
Track PAM programme completeness
Monitor privileged activity volume anomalies
Understand privileged account estate composition
Visualise cloud entitlement risk by platform
Track Entra ID governance maturity
Enforce guest identity governance
Governance committee view of programme delivery
Escalation list for overdue risk reviews
Demonstrate compliance posture for audit

RISK REGISTER — SUMMARY STATISTICS				
INHERENT RISK DISTRIBUTION				
Risk Level	Count	% of Total		
Critical	0	0.0%		
High	11	55.0%		
Medium	9	45.0%		
Low	0	0.0%		
Total	20			
RESIDUAL RISK DISTRIBUTION				
Risk Level	Count	% of Total		
Critical	8	40.0%		
High	9	45.0%		
Medium	3	15.0%		
Low	4	15.0%		
Total	20			

LESSON LEARNED

Key Observations

- Identity governance weaknesses were identified as the primary driver of residual IAM risk.
- Manual joiner, mover and leaver processes introduced elevated risk across multiple control domains.
- Access review completion rates and privileged access governance presented the largest opportunity for improvement.
- Strong alignment exists between IAM governance maturity and overall security posture.



nains.
unities for risk reduction.

No Critical risks were identified at the current stage of assessment. However, several High-rated risks require prioritised remediation due to their potential impact on privileged access management, identity governance and cloud identity security